

ПРИЛОЖЕНИЕ № 1

СПОРАЗУМЕНИЕ ЗА ОБРАБОТКА НА ЛИЧНИ ДАННИ

(Data Processing Agreement / DPA)

към Договор за изработка на интернет страница № от Г.

Днес, 20..... г., между:

1. „БУУКА“ ЕООД, ЕИК 208363525, със седалище и адрес на управление: гр. Варна 9000, ул. „Генерал Киселов“ № 10, представлявано от управителя, наричано по-долу „ОБРАБОТВАЩ“ (Processor),

и

2., ЕИК / БУЛСТАТ, със седалище и адрес на управление:, представлявано от, в качеството му на, наричано по-долу „АДМИНИСТРАТОР“ (Controller),

(заедно наричани „Страните“),

се сключи настоящото Споразумение за обработка на лични данни (наричано по-долу „Споразумението“ или „DPA“), което е неразделна част от основния Договор и се прилага във всички случаи, в които ОБРАБОТВАЩЪТ обработва лични данни от името на АДМИНИСТРАТОРА.

1. ДЕФИНИЦИИ

В настоящото DPA понятията „лични данни“, „обработване“, „администратор“, „обработващ“, „субект на данни“, „нарушение на сигурността на личните данни“, „надзорен орган“ имат значенията, дадени им в Регламент (ЕС) 2016/679 (GDPR).

„Основен договор“ означава Договорът за изработка на интернет страница, към който е сключено настоящото DPA, заедно с всички приложения и допълнителни споразумения.

„Подизпълнител“ (sub-processor) означава трето лице, ангажирано от ОБРАБОТВАЩИЯ за извършване на дейности по обработване от името на АДМИНИСТРАТОРА.

2. ПРЕДМЕТ И ПРОДЪЛЖИТЕЛНОСТ

2.1. Настоящото DPA урежда обработването на лични данни, което ОБРАБОТВАЩЪТ извършва от името на АДМИНИСТРАТОРА в рамките на:

- разработка, поддръжка и хостинг на интернет страницата на АДМИНИСТРАТОРА;
- функциониране на системата за онлайн резервации;
- изпращане на транзакционни съобщения (потвърждения, напомнящи имейли);
- свързани спомагателни дейности по основния Договор.

2.2. Срокът на DPA съвпада със срока на основния Договор. След прекратяване на основния Договор задълженията на ОБРАБОТВАЩИЯ относно връщане/изтриване на данните и поверителност продължават да действат съгласно т. 10 и т. 12 по-долу.

3. ХАРАКТЕР, ЦЕЛ И ВИД НА ОБРАБОТВАНЕТО

3.1. Характер на обработването: автоматизирано обработване чрез информационни системи, включващо събиране, съхранение, организиране, преглеждане, използване, прехвърляне (до подизпълнители), ограничаване и изтриване на лични данни.

3.2. Цели на обработването:

- приемане, обработване и съхранение на резервации;
- изпращане на потвърждения и напомнящи съобщения към субектите на данни;
- осигуряване на работоспособност, сигурност и поддръжка на интернет страницата;
- съдействие на АДМИНИСТРАТОРА при изпълнение на негови законови задължения и упражняване на права на субектите на данни.

3.3. Видове лични данни: в зависимост от конфигурацията, обявена в основния Договор:

- идентификационни (име, фамилия);
- контактни (имейл, телефон);
- данни за резервацията (дата, час, услуга, забележки, въведени от субекта);
- технически данни (IP адрес, браузър, устройство, бисквитки);
- данни за плащане (обработват се пряко от Stripe — виж т. 6.3);
- (други, ако приложимо).

3.4. Категории субекти на данни:

- крайни клиенти на АДМИНИСТРАТОРА, които правят резервации през сайта;
- посетители на сайта;
- служители или други лица, упълномощени от АДМИНИСТРАТОРА за административен достъп.

3.5. При първоначална настройка на сайта АДМИНИСТРАТОРЪТ може писмено да разшири или ограничи горепосочените категории.

3.6. Специални категории лични данни: ОБРАБОТВАЩЪТ не обработва съзнателно специални категории лични данни по чл. 9 GDPR (вкл. здравни данни). Ако дейността на АДМИНИСТРАТОРА (напр. медицински, козметичен или фитнес център) предполага обработване на такива данни през сайта, АДМИНИСТРАТОРЪТ носи отговорност за съответното правно основание и информира писмено ОБРАБОТВАЩИЯ, така че да бъдат въведени допълнителни технически и организационни мерки.

4. ИНСТРУКЦИИ НА АДМИНИСТРАТОРА

4.1. ОБРАБОТВАЩЪТ обработва личните данни **само** по документирани инструкции на АДМИНИСТРАТОРА. Настоящото DPA, основният Договор и неговите приложения представляват пълни документирани инструкции при подписването. Допълнителни инструкции се дават писмено (включително по електронна поща).

4.2. ОБРАБОТВАЩЪТ незабавно уведомява АДМИНИСТРАТОРА, ако счита, че дадена инструкция нарушава GDPR или други приложими разпоредби за защита на личните данни.

4.3. Когато ОБРАБОТВАЩЪТ е длъжен по силата на правото на ЕС или българското право да извърши обработване извън инструкциите на АДМИНИСТРАТОРА, той го информира за това правно изискване преди обработването, освен ако правото не забранява такова информирание по съображения от важен обществен интерес.

5. ЗАДЪЛЖЕНИЯ НА ОБРАБОТВАЩИЯ

ОБРАБОТВАЩЪТ се задължава:

5.1. да обработва личните данни единствено за целите по т. 3 и съгласно инструкциите по т. 4;

5.2. да осигури поверителност, като персоналът му, който има достъп до лични данни, е задължен с подходяща клауза за конфиденциалност и е инструктиран в основите на защитата на личните данни;

5.3. да приложи подходящи технически и организационни мерки за сигурност по т. 7;

5.4. да съдейства на АДМИНИСТРАТОРА (доколкото е приложимо и в рамките на разумно осъществимото) за изпълнение на задълженията му по чл. 32–36 GDPR и по упражняване на права на субектите на данни (т. 8);

5.5. да поддържа регистър на дейностите по обработване, които извършва от името на АДМИНИСТРАТОРА, съгласно чл. 30, пар. 2 GDPR;

5.6. да предоставя на АДМИНИСТРАТОРА цялата информация, необходима за доказване на спазването на чл. 28 GDPR, и да позволява провеждане на одити при условията по т. 11;

5.7. при поискване да върне или изтрие данните съгласно т. 12.

6. ПОДИЗПЪЛНИТЕЛИ (SUB-PROCESSORS)

6.1. АДМИНИСТРАТОРЪТ дава общо предварително разрешение на ОБРАБОТВАЩИЯ да ангажира подизпълнители за изпълнение на задълженията си по основния Договор.

6.2. Към датата на подписване на настоящото DPA, ОБРАБОТВАЩЪТ ползва следните подизпълнители:

Подизпълнител	Дейност	Местонахождение / гаранции
Vercel Inc.	Хостинг и доставка на сайта	САЩ / глобален edge — Стандартни договорни клаузи (SCCs) + DPA
Stripe Payments Europe Ltd.	Обработка на плащания	Ирландия (ЕС) — независим администратор по отношение на платежните данни
Resend, Inc.	Изпращане на транзакционни имейли	САЩ — SCCs + DPA
Google Ireland Ltd. (Google Analytics 4)	Уеб аналитика (при дадено съгласие от посетителя)	ЕС / САЩ — SCCs + EU-US Data Privacy Framework

6.3. Stripe действа като **самостоятелен администратор** по отношение на данните, които събира в качеството си на платежна институция (платежно нареждане, идентификация на картата, AML/KYC). Това обработване не е предмет на настоящото DPA.

6.4. При намерение да добави или замени подизпълнител ОБРАБОТВАЩЪТ уведомява АДМИНИСТРАТОРА предварително (по електронна поща или чрез актуализация на списъка на сайта на ИЗПЪЛНИТЕЛЯ) и предоставя поне **14 (четирнадесет) календарни дни** за писмено възражение. При обосновано възражение Страните преговарят добросъвестно за алтернативно решение. Ако такова не бъде намерено, АДМИНИСТРАТОРЪТ има право да прекрати засегнатата част от Услугите.

6.5. ОБРАБОТВАЩЪТ налага на всеки подизпълнител договорни задължения за защита на данните, не по-малко строги от настоящото DPA, и носи отговорност за действията на подизпълнителите си, все едно са негови.

7. МЕРКИ ЗА СИГУРНОСТ

7.1. ОБРАБОТВАЩЪТ прилага подходящи технически и организационни мерки по чл. 32 GDPR, включително:

- криптиране на трафика (TLS) и криптиране на данните в покой, където е технически възможно;
- съхранение на пароли чрез хеширане и сол;
- контрол на достъпа на принципа на „най-малкото необходимо ниво на достъп“;
- редовни прегледи на достъпа и закриване на неактивни акаунти;
- сканиране за уязвимости и навременно обновяване на софтуерни зависимости;
- одит логове за административни действия;
- защита срещу brute-force атаки (rate limiting);
- сигурни процедури за разработка (separate environments, code review);
- документираны процедури за реакция при инциденти;
- периодично архивиране на данните;
- проверка на доставчиците (vendor due diligence) и подписани DPA-та с подизпълнителите.

7.2. Мерките подлежат на периодична преоценка и могат да бъдат актуализирани в съответствие с развитието на технологиите и обема на обработването. Подобренията не могат да понижават нивото на защита.

8. ПОДПОМАГАНЕ ПРИ ПРАВА НА СУБЕКТИ И ЗАДЪЛЖЕНИЯ НА АДМИНИСТРАТОРА

8.1. ОБРАБОТВАЩЪТ съдейства на АДМИНИСТРАТОРА (с подходящи технически и организационни мерки, доколкото е възможно) за изпълнение на задължението му да отговаря на искания на субекти на данни относно:

- право на достъп (чл. 15);
- право на коригиране (чл. 16);
- право на изтриване / „забравяне“ (чл. 17);
- право на ограничаване (чл. 18);
- право на преносимост (чл. 20);
- право на възражение (чл. 21);
- права свързани с автоматизирано вземане на решения (чл. 22).

8.2. Ако ОБРАБОТВАЩЪТ получи пряко искане от субект на данни, той не отговаря по същество, а в рамките на 5 работни дни препраща искането към АДМИНИСТРАТОРА.

8.3. ОБРАБОТВАЩЪТ оказва на АДМИНИСТРАТОРА разумна помощ и за изпълнение на задължения по чл. 32–36 GDPR (сигурност, уведомяване за инциденти, оценка на въздействието и предварителни консултации).

8.4. Помощта по т. 8 е безплатна в обичаен обем; при системни, повтарящи се или явно прекомерни искания ОБРАБОТВАЩЪТ има право да начисли разумна такса.

9. НАРУШЕНИЕ НА СИГУРНОСТТА НА ЛИЧНИТЕ ДАННИ

9.1. При установяване на нарушение на сигурността на личните данни, обработвани от името на АДМИНИСТРАТОРА, ОБРАБОТВАЩЪТ го уведомява **без неоправдано забавяне** и не по-късно от **72 (седемдесет и два) часа** от узнаването, по електронна поща на адреса за контакт на АДМИНИСТРАТОРА.

9.2. Уведомлението съдържа поне:

- описание на естеството на нарушението;
- категории и приблизителен брой засегнати субекти и записи;
- вероятни последици;
- предприети или предложени мерки за справяне с нарушението и за намаляване на негативните последици;
- данни за контакт за допълнителна информация.

9.3. Ако цялата информация не може да бъде предоставена едновременно, тя се изпраща поетапно без неоправдано забавяне.

10. ПРЕДАВАНЕ НА ДАННИ В ТРЕТИ ДЪРЖАВИ

10.1. Доколкото обработването от подизпълнители (т. 6) включва предаване на лични данни извън ЕИП, ОБРАБОТВАЩЪТ гарантира, че е налице поне едно от следните основания по Глава V GDPR:

- решение на Европейската комисия за адекватно ниво на защита (вкл. EU-US Data Privacy Framework);
- Стандартни договорни клаузи (Решение за изпълнение (ЕС) 2021/914);
- други предвидени в GDPR подходящи гаранции.

10.2. Копия от приложимите гаранции се предоставят на АДМИНИСТРАТОРА при писмено искане.

11. ОДИТИ И ИНСПЕКЦИИ

11.1. АДМИНИСТРАТОРЪТ има право да поиска от ОБРАБОТВАЩИЯ необходимата информация и документи, доказващи спазването на настоящото DPA, един път годишно или по-често — ако е налице конкретно основание за безпокойство (напр. след инцидент).

11.2. При искане за одит на място Страните се споразумяват за разумен срок (не по-кратък от 30 дни), обхват и условия. Одитът се извършва в работно време, без необосновано смущение на дейността на ОБРАБОТВАЩИЯ, и при подписана клауза за поверителност.

11.3. Разходите за одит са за сметка на АДМИНИСТРАТОРА. Ако одитът установи съществено неизпълнение от страна на ОБРАБОТВАЩИЯ, той поема разходите за повторен одит за проверка на отстраняването.

11.4. Когато това е достатъчно, искания за информация се удовлетворяват чрез предоставяне на актуални доклади или сертификати на ОБРАБОТВАЩИЯ или на подизпълнителите му.

12. ВРЪЩАНЕ И ИЗТРИВАНЕ НА ДАННИ

12.1. При прекратяване на основния Договор, по избор на АДМИНИСТРАТОРА, ОБРАБОТВАЩЪТ:

- връща всички лични данни в общоприет, структуриран и машинночетим формат; и/или
- изтрива всички съществуващи копия,

в срок до **60 (шестдесет) календарни дни** от прекратяването, освен ако правото на ЕС или българското право не изисква по-дълго съхранение.

12.2. Резервни копия (backups) се изтриват автоматично в рамките на обичайния цикъл на пренаписване (до 30 дни).

12.3. При поискване ОБРАБОТВАЩЪТ предоставя писмено потвърждение за извършеното изтриване.

13. ОТГОВОРНОСТ

13.1. Отговорността на ОБРАБОТВАЩИЯ по настоящото DPA се урежда заедно и подчинено на ограниченията за отговорност, предвидени в основния Договор.

13.2. Нищо в настоящото DPA не ограничава отговорностите, които не подлежат на ограничаване по приложимото право, включително отговорността пред субектите на данни и пред надзорния орган по силата на чл. 82 GDPR.

14. ПРИЛОЖИМО ПРАВО И СПОРОВЕ

14.1. За настоящото DPA се прилага българското право.

14.2. Споровете се решават чрез преговори, а при липса на съгласие — от компетентния български съд по седалището на ОБРАБОТВАЩИЯ.

15. ЗАКЛЮЧИТЕЛНИ РАЗПОРЕДБИ

15.1. В случай на противоречие между настоящото DPA и основния Договор, по въпроси, свързани със защитата на лични данни, приоритет имат разпоредбите на настоящото DPA.

15.2. Изменения и допълнения се правят само в писмена форма с допълнително споразумение, подписано от Страните.

15.3. Настоящото DPA е изготвено и подписано в **2 (два)** еднообразни екземпляра — по един за всяка от Страните.

ЗА ОБРАБОТВАЩИЯ:	ЗА АДМИНИСТРАТОРА:
„БУУКА“ ЕООД, ЕИК 208363525	
_____	_____
.....	
Управител	Длъжност:
Дата:	Дата: